

Stoquify Agent Runtime Phase 2A Alert Evidence Capture Execution Report

Date: 2026-07-25

Decision: Repository implementation complete; external capture blocked pending a real evidence endpoint

Internal activation: Not attempted and not authorized

Phase 3: Not authorized

Executive Result

Stoquify now has a provider-neutral, fail-closed alert evidence collector for the Phase 2A controlled-pilot release boundary.

The collector converts a live, authenticated, production-like alert proof into a sanitized and SHA-256-bound register patch. It validates delivery, external request identity, acknowledgement within SLO, retry, dead-letter, protected recovery, backup escalation, and alert-secret rotation while retaining no secret value, authorization header, raw response, request body, database URL, environment snapshot, or tenant data.

The implementation does not activate an agent and cannot update any field outside the operational register's `alerting` section.

Implemented Artifacts

- `scripts/agent-alert-evidence-capture.js`
- `scripts/__tests__/agent-alert-evidence-capture.test.js`
- `docs/agents-runtime/STOQUIFY_AGENT_ALERT_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`
- `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_OPERATIONAL_RELEASE_EVIDENCE_2026-07-25.json`
- `scripts/agent-operational-release-gate.js`
- `scripts/agent-phase2a-command-gate.js`
- `.env.example`
- `package.json`

Security and Integrity Controls

Transport and authentication

- Query-free HTTPS is mandatory outside local development.
- Embedded URL credentials, query strings, and fragments are rejected.
- The collector requires a bearer value of at least 32 characters from the process environment.
- An ephemeral invalid credential is sent first and must receive `401`.
- The valid bearer value is never written to evidence or logs.
- Responses are bounded to 100 KB.

Sanitization

Only explicitly allowed alert fields survive the response boundary. Unknown fields are discarded before hashing, reporting, or register update.

References must be URI-style, contain no query or fragment, and carry no raw credential value. Owner identities must use `directory://` or `identity://` references and cannot contain test-fixture markers.

Temporal checks

- Delivery must be in the past and no older than 24 hours.
- Acknowledgement must not precede delivery.
- Acknowledgement must occur within the declared 1-to-120-minute SLO.
- Escalation proof must be in the past and must not precede delivery.

Ownership binding

At apply time:

- the acknowledger must match the operational register's primary `SECURITY_INCIDENT` owner;
- the escalation target must match the primary `ON_CALL_BACKUP` owner;
- the capture environment must match the release environment.

Mutation boundary

The updater preserves, byte-for-byte at the object level:

- release identity;
- CI evidence;
- product and security approvals;
- all owner records;
- scheduler evidence;
- credential-rotation binding;
- declared release status;
- activation fields.

It refuses any register where activation is requested, authorized, or recorded.

Commands Added

```
npm run agent:alert:evidence:report
npm run agent:alert:evidence:gate
npm run agent:alert:evidence:apply
```

The apply command updates only a ready, environment-matched, owner-bound alert capture.

Operational Gate Hardening

The operational release gate now requires:

```
alerting.evidenceSha256
```

A set of alert references without the exact sanitized capture hash can no longer satisfy independent review. The current operational register remains correctly `BLOCKED` with 146 external evidence blockers and always reports:

activationAuthorized: false

Verification

Verification	Result
Alert collector tests	9 passed
Operational gate tests	15 passed
Reconciler collector tests	8 passed
Focused evidence suites	3 suites, 32 tests passed
Focused open-handle detection	Passed; no leaked handle identified in the new suites
Complete Jest	473 suites and 2,852 tests passed; 3 suites and 15 tests skipped; intermittent forced-worker-exit warning observed after completion
Phase 2A static ratchet	Passed
Operational release report	<code>BLOCKED</code> , 146 blockers, activation false
Real alert collector preflight	Failed closed on <code>ALERT_EVIDENCE_URL_MISSING</code>
Secret values printed	No

The latest complete Jest run passed all tests but emitted an intermittent forced-worker-exit warning after completion. A focused rerun of all seven credential collector, credential gate, CI/release, governance, operational, alert, and reconciler evidence suites with `--detectOpenHandles` passed 73 tests cleanly and identified no open handle. The preflight failure is expected and correct. No managed external alert evidence endpoint or bearer configuration exists in the current workspace, so no evidence artifact or register update was fabricated.

External Endpoint Contract

The complete field contract, configuration, evidence procedure, and failure rules are defined in:

`docs/agents-runtime/STOQUIFY_AGENT_ALERT_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The endpoint must return sanitized proof for:

1. healthy alert transport;
2. HTTPS delivery and external request identity;
3. named-owner acknowledgement within SLO;
4. retry;
5. terminal dead-letter;
6. protected recovery;
7. named backup escalation;
8. alert-secret rotation.

Remaining External Work

This implementation closes the repository tooling gap, not the real-world evidence gap. Completion still requires:

- a deployed production-like alert receiver and evidence endpoint;
- managed webhook and evidence-endpoint secrets;
- a real security incident owner and on-call backup owner;
- real delivery, acknowledgement, retry, dead-letter, recovery, escalation, and rotation events;
- immutable evidence references exposed through the sanitized endpoint.

After those prerequisites exist, run:

```
npm run agent:alert:evidence:apply  
npm run agent:operational-release:gate
```

The release can advance only to independent review. Activation remains a separate protected ceremony, and Phase 3 remains unauthorized.